

Clase 283 — Continuidad de negocio y plan de recuperación ante desastres

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: (ISC)² CISSP Official Study Guide e ISO 22301 🕒
Duración estimada: **120 min** · Nivel: **Intermedio**

Objetivo

Aprender a diseñar un Plan de Continuidad de Negocio (BCP) y un Plan de Recuperación ante Desastres (DRP) que permitan a una organización sobrevivir a incidentes graves: ransomware, incendio, caída de proveedor cloud o desastre natural. Al terminar sabrás ejecutar un Análisis de Impacto en el Negocio (BIA), calcular RTO/RPO/MTD, elegir estrategias de recuperación y probar los planes con simulacros.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Diferenciar** BCP de DRP y su ámbito.
2. **Ejecutar** un BIA identificando procesos críticos y su impacto en el tiempo.
3. **Calcular** RTO, RPO y MTD para un proceso.
4. **Seleccionar** estrategias de recuperación (sitios frío/tibio/caliente, backups, HA).
5. **Diseñar** una prueba del plan (tabletop, simulacro, failover).

Temas

#	Tema	Por qué importa
1	BCP vs. DRP vs. respuesta a incidentes	Distintos alcances, mismo objetivo: resiliencia
2	BIA (Business Impact Analysis)	Base de todo el plan
3	Métricas: RTO, RPO, MTD, WRT	Cuantifican la tolerancia a la interrupción
4	Estrategias de recuperación	Cómo restaurar según criticidad
5	Sitios alternativos (frío/tibio/caliente)	Trade-off coste vs. rapidez
6	Estrategia de backups (3-2-1)	Última línea contra ransomware
7	Pruebas y mantenimiento del plan	Un plan sin probar no existe

Definiciones y características

- **BCP:** plan para mantener las funciones críticas del negocio durante y después de una interrupción. *Clave:* enfoque en procesos de negocio.
- **DRP:** plan para restaurar la infraestructura tecnológica tras un desastre. *Clave:* subconjunto técnico del BCP.

- **BIA:** análisis que identifica procesos críticos y el impacto de su interrupción en el tiempo. *Clave:* alimenta RTO/RPO.
- **RTO (Recovery Time Objective):** tiempo máximo tolerable para restaurar un proceso. *Clave:* "¿en cuánto tiempo debo volver?".
- **RPO (Recovery Point Objective):** máxima pérdida de datos tolerable en el tiempo. *Clave:* define la frecuencia de backup.
- **MTD (Maximum Tolerable Downtime):** interrupción total tras la cual el negocio no se recupera. *Clave:* $RTO < MTD$ siempre.
- **Sitio caliente/tibio/frío:** instalación de respaldo con distinto grado de preparación. *Clave:* más caliente = más rápido y más caro.

Herramientas y preparación

- Hoja de cálculo para el BIA y las métricas.
- Referencia: *ISO 22301* (continuidad de negocio) y *NIST SP 800-34* (Contingency Planning Guide).
- Para el laboratorio técnico opcional: una VM y un servicio simple (contenedor Docker) para practicar backup/restore.
- Herramientas de backup reales: `restic`, `borgbackup` o `rsync` para demostrar la regla 3-2-1.

Laboratorio guiado (ejercicio aplicado)

Parte A — BIA y métricas para "Ferretería del Sur S.A.":

1. **Inventario de procesos:** lista 5 procesos (venta online, procesamiento de pagos, atención al cliente, facturación, marketing).
2. **Impacto en el tiempo:** para cada proceso, estima el impacto (€/hora de caída) a 1 h, 8 h, 24 h y 72 h.
3. **Críticidad:** clasifica cada proceso en crítico/importante/no crítico según su impacto.
4. **RTO/RPO/MTD:** asigna a cada proceso crítico un MTD, un RTO ($< MTD$) y un RPO. Ej.: pagos → MTD 4 h, RTO 1 h, RPO 15 min.
5. **Estrategia de recuperación:** para cada proceso crítico elige la estrategia (HA activo-activo, sitio caliente, restauración desde backup) coherente con su RTO/RPO.

Parte B — Backup 3-2-1 real (VM):

6. Crea datos de ejemplo y un repositorio restic:

```
mkdir -p /srv/datos && echo "pedido-001" > /srv/datos/pedido.txt
restic init --repo /srv/backup
restic backup /srv/datos --repo /srv/backup
```

7. Simula un "desastre" borrando los datos y restaura:

```
rm -rf /srv/datos/*
restic restore latest --repo /srv/backup --target /
cat /srv/datos/pedido.txt # verifica que recuperas el dato
```

8. Mide el tiempo de restauración y compáralo con tu RTO objetivo.

Parte C — Prueba del plan:

9. Diseña un ejercicio **tabletop**: escribe un escenario de ransomware y 6 preguntas que el equipo debe responder (quién declara el desastre, a quién se avisa, en qué orden se restaura).

Ejercicios

1. Explica la diferencia entre RTO y RPO con un dibujo temporal.
2. ¿Por qué el RTO siempre debe ser menor que el MTD?
3. Ordena sitios frío, tibio y caliente por coste y por velocidad de recuperación.
4. Aplica la regla 3-2-1 a un escenario y explica cómo protege frente a ransomware.
5. Diseña un BIA de 3 procesos para una clínica dental.
6. Propón tres tipos de prueba del plan y cuándo usar cada una.

Reto verificable

Entrega un **BCP/DRP mínimo viable** con: BIA de al menos 5 procesos, tabla RTO/RPO/MTD de los críticos, estrategia de recuperación por proceso, y evidencia de un backup/restore real (tiempo medido) más el guion de un ejercicio tabletop.

Criterio de aceptación: todo proceso crítico tiene $RTO < MTD$ y un RPO coherente con su frecuencia de backup, la restauración real funciona (dato recuperado) y su tiempo se compara con el RTO objetivo.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Backups que nunca se prueban al restaurar	Un backup sin restore verificado no es un backup; prueba periódicamente
RTO/RPO fijados sin BIA	Números arbitrarios; deriva de impacto en el negocio
Backups en la misma red que producción	El ransomware los cifra también; usa copias inmutables/offline
Confundir alta disponibilidad con backup	HA protege de fallo de hardware, no de borrado/cifrado malicioso
Plan escrito pero nunca ejercitado	Falla en el peor momento; haz tabletops y simulacros

Preguntas frecuentes

-  **¿BCP y DRP son lo mismo?** No. El BCP cubre todo el negocio (personas, procesos, instalaciones); el DRP es la parte tecnológica de restaurar sistemas. El DRP vive dentro del BCP.
-  **¿Qué es la regla 3-2-1?** Tres copias de los datos, en dos medios distintos, con una copia fuera de sitio (offsite). La variante 3-2-1-1-0 añade una copia inmutable/air-gapped y cero errores verificados.
-  **¿Cada cuánto pruebo el plan?** Tabletops al menos anualmente; simulacros de failover según criticidad. Cada prueba genera lecciones que actualizan el plan.
-  **¿La nube me exime de tener DRP?** No. La nube reparte responsabilidades pero tú sigues siendo responsable de tus datos, configuraciones y RTO/RPO. Diseña recuperación multi-AZ/multi-región según

necesites.

Referencias

- ISO 22301:2019 — Business Continuity Management. <https://www.iso.org/standard/75106.html>
- NIST SP 800-34 Rev.1 — Contingency Planning Guide. <https://csrc.nist.gov/pubs/sp/800/34/r1/final>
- (ISC)² CISSP Official Study Guide, dominio 7.
- restic — Backups rápidos, seguros y verificables. <https://restic.net/>
- Estrategia de backup 3-2-1 (CISA). <https://www.cisa.gov/>

Siguiente clase

Clase 284 - Gestion de riesgo de terceros y proveedores